

CODEBASE AUDIT

POgrid.id

Multi-tenant Production Order Tracking SaaS

Laravel 11 · Inertia.js v2 · React 18 · TypeScript · Tailwind v4

Date: 12 August 2026

Scope: Full-stack review — backend, frontend, security, tests & infrastructure

Method: static analysis (4 parallel review passes), tsc --noEmit, knowledge-graph traversal

7

CRITICAL

14

HIGH

21

MEDIUM

18

LOW / INFO

1. Executive Summary

POgrid is a well-conceived multi-tenant SaaS with a genuinely strong domain core: the observer-driven progress engine, additive-delta progress model, QC-rework sub-stages, and sunk-cost protection are thoughtful designs with **excellent feature-test coverage (~6,700 LOC across 14 feature suites)**. Tenant isolation on worker mutating endpoints is verified solid, and there is no `$request->all()` mass-assignment usage anywhere in the codebase.

However, the audit surfaces **7 critical issues** in two clusters:

- **Authorization collapse (backend):** the `verified` middleware is a no-op (`User` doesn't implement `MustVerifyEmail`), so every “office” route is reachable by any authenticated floor worker. Combined with a permissive `UserPolicy::manage` and an ungarded PIN-reset approval endpoint, this enables **full tenant-admin account takeover from a 4-digit PIN session**. A cross-tenant write IDOR in PPIC endpoints and a logo-upload RCE path complete the critical set.
- **Runtime crashes (frontend):** two components throw ReferenceErrors on render — the Worker floor dashboard (the most-used page) and the Owner Dashboard matrix tab. TypeScript reports **561 compile errors** that never surface because the build pipeline does not type-check.

Verdict: domain architecture and test culture are above average for a product at this stage. Security authorization and frontend type discipline are below the bar for production with real tenant data. All critical findings are fixable with small, surgical changes (see §7).

Contents

2. Architecture Overview

3. Backend Review

4. Frontend Review
5. Security Review (detailed)

6. Tests, CI/CD & Infrastructure

7. Prioritized Action Plan

8. Positive Patterns Worth Keeping

2. Architecture Overview

LAYER	DESIGN	ASSESSMENT
Multi-tenancy	Row-level <code>TenantScope</code> + <code>TenantManager</code> singleton, <code>Belongs ToTenant</code> trait	FAILS OPEN — M1 §5
Business logic	Observer chain: <code>ItemObserver</code> → auto <code>ItemProgress</code> ; <code>ItemProgressObserver</code> → weighted progress cascade; <code>DoItemObserver</code> → PO DELIVERED	GOOD — logic out of controllers, well-tested
Auth	Dual guard: office (password) + floor (4-digit PIN, throttled)	BROKEN GATES — C1–C3 §5
Frontend	Inertia v2 SPA, 3 page groups, shared AppShell chrome, 8 themes via CSS vars	MIXED — no code splitting, inline-style dominant
Realtime	Pusher private presence channels per tenant + 30s polling fallback	OK

i18n	EN/ID locale JSONs + <code>useTranslation</code>	3 PARALLEL MECHANISMS — \$4.5
Infra	Hostinger shared hosting, Neon PostgreSQL, cron-driven queues, rsync deploy	FRAGILE DEPLOY — \$6.4

3. Backend Review

3.1 Routes

LOCATION	SEV	FINDING
<code>routes/web.php:28</code>	HIGH	Office <code>POST /login</code> has no throttle — privileged passwords brute-forceable without limit. PIN login is throttled (5/min); office login should be too.
<code>routes/web.php:91</code>	CRIT	<code>POST /pin-reset/{alertId}/approve</code> marked “admin only” in comment but has no role gate . See C3 §5.
<code>routes/web.php:107</code>	MED	Guest <code>pin-reset/request</code> unthrottled; worker IDs public via floor login page → alert-flood / pre-positioning for C3.
<code>routes/web.php:59</code>	CRIT	Entire <code>auth,verified</code> group effectively <code>auth</code> -only — verification middleware is a no-op. See C1 §5.
<code>routes/web.php:94-97</code>	LOW	Duplicate route pairs (<code>/dashboard/billing</code> + <code>/billing</code> etc.) — doubled surface, harmless.

3.2 Controllers

- **God-controllers:** `WorkerDashboardController.php` = 1,946 lines / 16 public methods (progress + QC + finance + stage-gate + telemetry). `OwnerDashboardController.php` = 878 lines / 21 methods. Extract telemetry (`getTelemetryData` ~500 LOC) and `validateStageAccess` (~140 LOC) into services.
HIGH MAINTAINABILITY
- **No FormRequest classes** — all validation inline; consistent and complete, but password policy diverges (registration min:8+number vs changePassword min:6). MED
- `PinResetController.php:46` — creates alert with `item_id = 0` on a non-nullable FK → likely 500s on PostgreSQL prod. Untested path. HIGH
- `PinResetController.php:83` — new PIN written **plaintext into alerts table** (persisted + broadcast). Credential at rest in a log table. HIGH
- No `$request->all()` anywhere; controllers build explicit attribute arrays. PASS

3.3 Models / Observers / Services

- Observer chain correct and well-tested; no infinite-loop path found in recalculation cascade. PASS
- `app/Models/Tenant.php` retains duplicate-namespace quirk (documented) — works, confusing. LOW
- `User $fillable` includes `is_owner` / `tenant_id` — safe today (explicit arrays), but guard `is_owner` against future regressions. INFO
- `ItemPolicy::updateStage` is an allow-all stub; real checks live in `validateStageAccess()` — remove or implement to avoid false confidence. INFO

4. Frontend Review

4.1 Critical Runtime Defects (ship-blockers)

C6 — Worker floor dashboard crashes on render

resources/js/Pages/Worker/Dashboard.tsx:1858

`translations={translations}` — identifier never defined in scope (hook migration casualty: old `translations` object → `useTranslation`). TS2304. Any render with `items.length > 0` throws `ReferenceError` → white screen on the most-used page in the product.

C7 — Owner Dashboard matrix tab crashes on render

resources/js/Components/OwnerDashboard/ActiveDelayDirectory.tsx:12,35,131,207,290

Component destructures 8 props but references 8 more (`setDirCollapsed` , `telemetry` , `alerts` , ...) never passed by `Owner/Dashboard.tsx:3306-3315` . 25 tsc errors in this file. Refactor casualty — logic moved into child component, state left in parent.

Root cause of both: `npm run build` = plain `vite build` ; esbuild strips types without checking. Measured **561 tsc errors across 30 files**. `tsconfig.json` exists (AGENTS.md stale on this point) but `strict: false` and nothing runs it. Fix: add `"typecheck": "tsc --noEmit"` and wire it into build + CI.

4.2 Typing

LOCATION	SEV	FINDING
<code>il8n/useTranslation.ts:39</code>	HIGH	<code>@ts-ignore</code> makes every <code>t.*</code> access untyped — direct root cause of ~400 of the 561 errors and of C6-style bugs. Missing keys fail silently at runtime.
<code>Owner/Dashboard.tsx</code>	HIGH	45 <code>any</code> usages; <code>telemetry?: any</code> (:236) — largest data structure on most complex page untyped, propagates into every OwnerDashboard sub-component.
<code>types/index.d.ts</code>	HIGH	Shared types defined but imported by zero files ; three divergent local <code>Item</code> interfaces across Worker/Owner dashboards + permissions.ts.
repo-wide	MED	~190 <code>any</code> / <code>as any</code> total (Owner/Dashboard 45, ActiveDelayDirectory 21, Worker/Dashboard 20, Ppic 16, PresentationMode 15).

4.3 State / localStorage

LOCATION	SEV	FINDING
<code>CreatePo.ts x:246-264</code>	HIGH	Draft restore uses truthiness-only checks — no shape/version validation. Draft from an older app version (<code>items</code> missing <code>required_stages</code>) explodes at render (<code>.length</code> of undefined) — same failure class as the recent blank-page incident. Add schema guard + version field.
<code>CreatePo.ts x:364</code>	LOW	<code>DRAFT_KEY</code> global, not per-tenant — draft bleeds across tenants in the same browser.

CreatePo.tsx:203-209	MED	Hardcoded demo client names (PT Astra Otoparts...) shown to all tenants — demo data leaking into production UX.
XSS review	PASS	No <code>dangerouslySetInnerHTML</code> , no <code>eval</code> . No credentials in localStorage. Pusher key arrives via page props only.

4.4 Forms & Error Handling

LOCATION	SEV	FINDING
Worker/Dashboard.tsx item mutations (:319-452, :733-805)	HIGH	Zero <code>onError</code> handlers on progress/kendala/rework/finance mutations — failures silently reset loading state; floor users (often on poor connectivity) see nothing.
CreatePo.tsx:356-366	MED	<code>router.post</code> lacks <code>onError</code> ; server validation errors render twice (toast + inline box :520-537).
Owner/Onboarding.tsx:20-33	MED	Parses temp password from flash success string via regex — fragile contract; any wording change silently drops the password display.
CreatePo.tsx:700	MED	<code>key={index}</code> on mutable items list — removal reuses wrong DOM state. Use stable per-item id.
Auth pages	PASS	<code>useForm</code> + <code>processing</code> guards + offline check — consistent, race-safe. CreatePo double-submit guarded (<code>submitting</code> flag + disabled buttons).

4.5 i18n

- **Three parallel mechanisms:** locale JSONs + `useTranslation`; ~250 inline `language === 'id' ? ... : '...'` ternaries (Owner/Dashboard 129, PresentationMode 39, Worker/Dashboard 29...); `Utils/locale.ts` STATUS_TRANSLATIONS map. Inline strings escape parity checking. **HIGH**
- Locale parity is otherwise near-perfect: exactly one dead key each side (`Owner_Logs.to` / `Owner_Logs.to`). **LOW**
- `AppLayout.tsx:42-49` maintains its own language state separate from `useTranslation` — two sources of truth; toggle doesn't re-render hook-based pages until reload. **MED**

4.6 Styling & Performance

EVIDENCE	SEV	FINDING
~1,200 <code>style={{}}</code> blocks	HIGH	Inline-style-dominant pages despite Tailwind v4 + theme vars. New object identity per render defeats memoization; hover states impossible → JS <code>onMouseOver</code> hacks (6 in CreatePo alone, break on touch).
Hardcoded colors (~250)	HIGH	e.g. <code>CreatePo.tsx:610</code> <code>'#10b981'</code> , <code>Errors/419.tsx</code> still old indigo <code>#6366f6</code> (brand drifted to blue <code>#2563eb</code>). These ignore all 8 themes — light theme gets dark-mode leftovers.
app.tsx:20	HIGH	No code splitting — all pages eager-bundled into one chunk graph. Landing visitors download the 4,200-line Owner Dashboard + Pusher + Echo + all locales.
Owner/Dashboard.tsx	HIGH	Zero <code>useMemo</code> ; <code>getUnifiedIssuesList()</code> recomputed ≥2×/render; 30s clock re-renders entire 4,200-line page.

app.css:6-9

PASS

Cascade-layer architecture correct (`@layer reset, astrix, theme, base, components, utilities`); 9 theme palettes defined — architecture is right, pages just don't use it consistently.

4.7 Duplication (systemic)

- `Worker/Dashboard.tsx:99-224` re-implements **all four** `Utils/permissions.ts` functions locally — and the copies **diverge** (missing ASSEMBLY/SURFACE/MAINTENANCE roles; OFFICE_ROLES lacks STAFF). Stage-gate behavior differs by which copy executes. **HIGH**
- Echo/Pusher wiring (~90 lines) copy-pasted across 3 dashboards. **HIGH**
- Language-toggle pill markup duplicated 4×. 30s clock interval in 5+ files. **MED**

5. Security Review (detailed)

C1 — `verified` middleware is a no-op → all office routes reachable by any authenticated user (incl. floor PIN workers)

app/Http/Middleware/EnsureEmailsVerified.php:18-31 · app/Models/User.php:11 · routes/web.php:59

Custom `EnsureEmailIsVerified` only blocks when user `instanceof MustVerifyEmail`. `User` does **not** implement it, so the check never triggers. The middleware also returns early in `testing` env, so the test suite cannot catch it. Effect: `/users`, `/pos`, `/company/update`, `/pin-reset/{id}/approve`, `/logs`, billing — all protected by `auth` only.

Exploit: any floor worker with a 4-digit PIN session can call every “office” endpoint directly.

Fix: replace the gate with an explicit `access-office` middleware (`role_level === 'office'`) on the route group. Remove the testing-env bypass. (Making User implement `MustVerifyEmail` would also force email-verification UX that isn't built — the role gate is the intended boundary.)

C2 — User-management endpoints allow floor workers to create office accounts / self-promote / reset coworker passwords

app/Http/Controllers/OwnerDashboardController.php:263-444 · app/Policies/UserPolicy.php:13-18

`UserPolicy::manage()` denies **only** Manager/Sales posts. Any other role — including floor roles authenticated via PIN — passes. Combined with C1: a floor worker can `POST /users` with an office STAFF `role_id` (create office login), `POST /users/{ownId}/update` with office `role_id` (self privilege escalation — role change at line 406 has no escalation guard), or reset an admin's password (only `is_owner` accounts are protected, line 366).

Exploit: login as any floor worker (demo PIN 0000) → `POST /users/{id}/update` with STAFF `role_id` + new username/password → office access.

Fix: restrict `manage` to office level; forbid non-owners from granting office-level roles; block role changes on self. Extend `RoleSecurityRemediationTest` to cover a floor-role actor.

C3 — PIN-reset approval has no authorization check → intra-tenant account takeover; new PIN stored plaintext

app/Http/Controllers/PinResetController.php:55-87 · routes/web.php:91

`approvePinReset()` has no Gate/policy (route comment says “admin only” — not enforced). New PIN written **plaintext** into `alerts.message` (persisted, broadcast) and flash. Request side is guest-accessible and unthrottled; worker IDs are public on the floor login page.

Exploit: attacker with any floor PIN: (1) as guest, request PIN reset for the FINANCE user; (2) as themselves, approve the alert; (3) read the victim's new PIN from the alert → log in as FINANCE → mark invoices PAID.

Fix: Gate `approvePinReset` to office/Admin; never persist the plaintext PIN (display once via flash only, or use a one-time token flow); throttle the request endpoint.

C4 — Cross-tenant write IDOR in PPIC endpoints

app/Http/Controllers/PpicDashboardController.php:358-379 (updatePo), :381-401 (updateItemPriority)

Both methods resolve tenant from the URL slug, pin `TenantManager` to it, and update — **without** `Gate::authorize('view-tenant', ...)` (which sibling methods do call). The `SetTenant` middleware's auth-user override (line 38) is undone by the controller re-pinning scope to the slug tenant.

Exploit: user of tenant A: `POST /c/{tenant-B-slug}/ppic/pos/{poId}/update` → modifies tenant B's PO deadline/urgency. Slugs are low-entropy.

Fix: add `Gate::authorize('view-tenant', $tenant->id)` + PPIC/office role gate to both methods.

C5 — Logo upload: client-controlled extension in public webroot → RCE

app/Http/Controllers/OwnerDashboardController.php:81-86

`'logo' => ['nullable', 'image', 'max:2048']` validates MIME content, but the filename uses `$file->getClientOriginalExtension()` with `move(public_path('uploads/logos'))`. A polyglot (valid PNG content, `.php` extension) passes `image` validation and lands executable in the webroot on Apache/PHP-FPM. No `.htaccess` in `public/uploads` disables the engine. Reachability widened by C1/C2.

Exploit: `POST /company/update` with logo = PNG+PHP polyglot named `shell.php` → `GET /uploads/logos/logo_1_*.php?cmd=id`.

Fix: use `storePublicly()` (hash name, MIME-guessed extension); serve from `storage/`; add `php_flag engine off` in `public/uploads/.htaccess`; tighten gate to office-only.

High

H1 — Telemetry aggregates leak across tenants via raw query builder

app/Http/Controllers/WorkerDashboardController.php:466-471, 494-499

`DB::table('do_items')->join('items', ...)` bypasses Eloquent → `TenantScope` never applied, no manual `items.tenant_id` filter. Delivered-volume metrics (and PDF/CSV/XLSX exports) sum **all tenants'** data. Aggregate-only leak.

Fix: add `->where('items.tenant_id', TenantManager::getTenantId())` to both queries.

H2 — No rate limiting on office password login

routes/web.php:28 - AuthController.php:13-53

Only PIN login throttled. Office passwords online-brute-forceable without limit; user enumeration (intentional, see L1) makes targeting easy.

Fix: `->middleware('throttle:5,1')` on `POST /login`.

H3 — Weak PIN policy: 4-digit, per-IP throttle only, no lockout

routes/web.php:106 - WorkerAuthController.php:38-76 - OwnerDashboardController.php:311-318

Keyspace 10k; 5/min per IP+route; ~33h single-IP to exhaust one account; worker list public. Bcrypt storage is correct.

Fix: 6-digit minimum, per-user_id throttle key, lockout/backoff after N failures.

H4 — Plaintext credential material in logs and flash

app/Providers/AppServiceProvider.php:133-163 - OwnerDashboardController.php:835 - PinResetController.php:83,86

Every outgoing email body (reset links, temp passwords) logged to `logs/verification-emails.log` — fires for production SMTP too, not just the log mailer. Temp password echoed in flash.

Fix: gate mail logger behind `app()->environment('local')`; remove temp password from flash; redact tokens.

Medium

ID	LOCATION	FINDING
M1	<code>app/Models/Scopes/TenantScope.php:12-22</code>	TenantScope fails open: no tenant set + not bypassed → no constraint → all tenants returned. Fail closed (<code>whereRaw('1=0')</code> or throw) unless explicitly bypassed.
M2	<code>routes/web.php:107</code>	Unauthenticated, unthrottled PIN-reset request endpoint — fan-out alert flood across all users of a tenant.
M3	<code>OwnerDashboardController.php:623,838,851</code>	Read-only office pages (rework logbook, billing, activity logs) lack role gates — with C1, floor workers read them.
M4	<code>config/session.php:172</code>	<code>SESSION_SECURE_COOKIE</code> unset — set <code>true</code> in prod .env; consider HSTS.

M5	4 controllers	Password policy inconsistent (min:8+number at registration vs min:6 elsewhere) — centralize <code>Password::min(8)->numbers()</code> .
M6	<code>app/Services/ExportService.php:63-82,174-192</code>	CSV/XLSX formula injection — user-supplied <code>client_name</code> / <code>item_name</code> starting with <code>= + - @</code> execute in Excel. Prefix with <code>'</code> .

Low / Info

- **L1** — Intentional user enumeration on office login (`user_not_found` vs `wrong_password`) is documented UX; accept, but pair with H2 throttling. Also gives a timing oracle (early return before `Hash::check`).
- **L2** — `exists:users,id` / `exists:users,email` validation rules reveal account existence globally.
- **L3** — Registration unthrottled → tenant spam / slug squatting.
- **L5** — Mass-assignment posture good; consider `$guarded` for `is_owner`.
- **L7** — `SetTenant` writes session keys from any visited slug before auth override — fragile but no leak found.
- **L8** — Email-verification feature effectively dead (see C1): wire it or delete it.

6. Tests, CI/CD & Infrastructure

6.1 Test Coverage

~6,700 LOC of feature tests across 14 files — strong coverage of tenant isolation, weighted progress (multi/single-piece), QC rework, stage gating, RED/YELLOW alerts, timeline cron + escalation, DO cascade, PO lifecycle, exports, broadcast isolation, PPIC metrics, role remediation. `TestCase` correctly resets `TenantManager`. Unit suite is effectively empty (all logic tested at HTTP level) — acceptable for this codebase's size.

GAP	SEV	DETAIL
PIN-reset flow untested	CRIT	<code>requestPinReset</code> → BLUE alert → approve → PIN shown — zero happy-path tests (only a cross-tenant denial test). The only credential-recovery path for floor workers; a regression strands them. (Also the path with the <code>item_id=0</code> FK bug — a test would have caught it.)
Forgot/reset password untested	HIGH	Guard A recovery: <code>Password::reset()</code> , token expiry, notification dispatch — nothing.
Email verification untested	HIGH	Controller + routes exist; middleware is a no-op (C1) so behavior is undefined either way.
ProfileController untested	MED	Profile update can change email/password — untested.
BackfillItemStages command untested	MED	Data-migration command; dangerous if re-run on prod.

Dialect risk (MED): tests run SQLite in-memory, prod is Neon PostgreSQL. Current risk is low (JSON columns used as arrays only, portable raw SQL), but PG boolean/integer strictness differences won't be caught. Recommend a pgsq CI job.

6.2 E2E (Puppeteer + Jest, ~1,400 LOC)

Covers both auth guards, dashboards, navigation, browser-level multi-tenant isolation, PO management.

Not wired into CI — the workflow runs only `php artisan test`. The suite that caught real multi-tenant bugs never runs on push. **MED** No browser test covers progress-update / QC-rework — core worker workflows are backend-tested only. **LOW**

6.3 Dependencies

ITEM	SEV	FINDING
<code>laravel/framework ^11.0</code>	HIGH	Laravel 11 security fixes ended March 2026 (now Aug 2026) — framework is EOL, no more security patches. Plan upgrade to 12.
<code>composer.json:87</code>	MED	<code>"policy.advisories.block": false</code> — composer audit won't block CVE-flagged packages; no <code>composer audit</code> in CI.
<code>phpunit ^10.5</code>	LOW	Security support ended Feb 2026 (dev-only) — upgrade with framework.
Vite 8 / plugin-react 6	MED	<code>npm install</code> requires <code>--legacy-peer-deps</code> — unresolved peer conflicts being papered over.
Skeleton leftovers	LOW	<code>"name": "laravel/laravel"</code> , skeleton description/license in <code>composer.json</code> ; unused pest plugin allowed.

6.4 CI/CD & Deploy

LOCATION	SEV	FINDING
<code>.github/workflows/deploy.yml:100-108</code>	HIGH	Deploy runs no migrations — rsync + cache rebuild only. Any shipped migration requires manual SSH; forget once → 500s. Add <code>php artisan migrate --force</code> .
<code>deploy.yml:93-98</code>	HIGH	rsync without <code>--delete</code> — deleted files linger on prod forever (stale compiled views were already an incident class).
<code>deploy.yml:60</code>	MED	<code>public/hot</code> still in upload-artifact paths — same confusion class as the original blank-page incident. Remove.
<code>package.json</code> vs <code>deploy.yml</code>	MED	Two divergent deploy paths (<code>npm run deploy</code> + GH Action) duplicate rsync exclusion lists — drift = incident repeat. Single source of truth needed.
<code>config/queue.php:106</code>	MED	Queue split-brain: jobs table on local SQLite (<code>DB_QUEUE_CONNECTION</code>) but <code>job_batches</code> falls back to <code>DB_CONNECTION=pgsql</code> (Neon) — verify migration ran there or pin the connection.
<code>routes/console.php</code>	LOW	Cron-driven <code>queue:work</code> + timeline evaluation — if host cron dies, alerts + queues silently stop. No health-check/monitor.

6.5 God-objects

FILE	LINES	SEV
<code>resources/js/Pages/Owner/Dashboard.tsx</code>	4,203	HIGH

<code>app/Http/Controllers/WorkerDashboardController.php</code>	1,946	HIGH
<code>resources/js/Pages/Worker/Dashboard.tsx</code>	1,879	MED
<code>resources/js/Pages/Landing/Landing.tsx</code>	1,399	LOW
<code>resources/js/Pages/Owner/CreatePo.tsx</code>	1,082	MED
<code>app/Http/Controllers/OwnerDashboardController.php</code>	878	MED

Zero TODO/FIXME/HACK comments in `app/` or `resources/js/` . **PASS**

7. Prioritized Action Plan

Week 1 — stop the bleeding (all small diffs)

#	ACTION	FINDINGS	EFFORT
1	Add <code>access-office</code> middleware (<code>role_level === 'office'</code>) to the office route group; remove testing bypass	C1, M3	~1h
2	Tighten <code>UserPolicy::manage</code> to office roles; block role self-change and office-role grants by non-owners	C2	~2h
3	Gate <code>approvePinReset</code> to Admin/Owner; stop persisting plaintext PINs; throttle request endpoint; fix <code>item_id=0</code> FK bug (nullable item_id or omit)	C3	~2h
4	Add <code>view-tenant</code> gate to PPIC <code>updatePo / updateItemPriority</code>	C4	~30m
5	Logo upload: <code>storePublicly()</code> + <code>.htaccess</code> engine-off in uploads	C5	~1h
6	Fix <code>translations={translations}</code> (Worker/Dashboard) + missing props (ActiveDelayDirectory); add <code>tsc --noEmit</code> to build & CI (gate on zero NEW errors initially)	C6, C7	~3h
7	Write PIN-reset + forgot-password happy-path tests	\$6.1	~3h

Weeks 2–4 — high severity

- Throttle office login (H2); 6-digit PIN + per-user lockout (H3); tenant filter on telemetry raw queries (H1); gate mail logger to local env (H4).
- TenantScope fail-closed (M1); draft-restore schema validation + per-tenant draft key (§4.3); dedupe permissions functions in Worker/Dashboard (§4.7); add `onError` to worker mutations (§4.4).
- Deploy: add `migrate --force`, decide `--delete`, remove `public/hot` artifact, unify manual + CI deploy scripts (§6.4).
- Plan Laravel 12 upgrade (framework EOL) (§6.3).

Quarter — structural

- Break up Owner/Dashboard.tsx (4.2k LOC) and WorkerDashboardController.php (1.9k LOC); extract telemetry + stage-gate services.

- Type `useTranslation` (keyed by locale JSON), adopt `types/index.d.ts` shared models, ratchet `strict: true`.
- Code-split pages (`React.lazy` per page group); consolidate 3 i18n mechanisms into locale JSONs; migrate inline styles to theme-aware classes.
- Pgsql CI test job; e2e smoke suite in CI; `composer audit` gate.

8. Positive Patterns Worth Keeping

- **Observer-driven domain logic** — progress cascades, QC rework spawning, DO completion live in observers, not controllers. Controllers stay thin; business invariants are testable and tested.
- **Additive-delta progress model** with the multi/single-piece weighted formula — mathematically sound, comprehensively tested.
- **Sunk-cost protection** — CANCELLED only at 0%, otherwise TERMINATED with finance trail. Genuinely good product thinking.
- **Tenant isolation on worker mutations** — verified solid; explicit `view-tenant` gates on read paths; presence-channel auth blocks cross-tenant subscription.
- **Feature-test culture** — 14 suites including remediation-specific tests (RoleSecurityRemediationTest) show regressions get tests, not just fixes.
- **No mass-assignment shortcuts, no XSS sinks, no TODO graveyard.**
- **Theme/cascade architecture** in app.css is correct — the fix is adoption, not redesign.
- **Flash-message UX** with localized error keys — thoughtful, consistent auth error handling.

POgrid.id codebase audit — 12 August 2026 — generated from static analysis of the working tree. Line numbers verified against source at audit time.